

MUSCLE CONTEST INTERNATIONAL



MANUAL DO SISTEMA

MCI Platform — sistema oficial de operação do
Campeonato Brasileiro Muscle Contest International

VERSÃO 1.0 · SETEMBRO DE 2026

CUIABÁ — MATO GROSSO
2026

MUSCLE CONTEST INTERNATIONAL

MANUAL DO SISTEMA

MCI Platform — sistema oficial de operação do Campeonato Brasileiro Muscle
Contest International

Documento técnico de referência destinado a administradores, operadores de evento, responsáveis técnicos e ao comitê esportivo, elaborado a partir do código-fonte do sistema e das regras homologadas do campeonato.

CUIABÁ — MATO GROSSO
2026

CONTROLE DE VERSÕES



Versão	Data	Natureza da alteração	Responsável
1.0	12/09/2026	Emissão inicial do manual, cobrindo arquitetura, papéis, módulos, regulamento aplicado, segurança, administração, implantação e diagnóstico.	Equipe técnica MCI

Classificação: documento técnico de circulação interna.

Vigência: substitui integralmente qualquer versão anterior.

Revisão recomendada: a cada temporada, ou a cada alteração do regulamento homologado.

RESUMO

Este manual descreve o MCI Platform, sistema oficial de operação do Campeonato Brasileiro Muscle Contest International. O documento apresenta a arquitetura em três componentes — servidor de aplicação, interface de página única e banco de dados relacional com isolamento por linha —, o modelo de autorização granular composto por vinte e um papéis e sessenta e seis permissões, e os módulos funcionais que cobrem o ciclo completo de uma etapa: cadastro de organizações e atletas, filiação, inscrição, operação do dia do evento, recepção e publicação de resultados oficiais, apuração de rankings e relacionamento entre participantes. Registra, ainda, o regulamento esportivo tal como implementado, incluindo a tabela de pontuação por colocação, o bônus de título Overall, a elegibilidade das classes ao Super Overall anual e o critério de desempate, que se encerra sem quebrar empates remanescentes. Descreve os controles de segurança adotados, entre eles a segurança em nível de linha aplicada pelo próprio banco de dados, o tratamento restrito do Cadastro de Pessoas Físicas e a trilha de auditoria de atos críticos. Delimita expressamente o escopo do sistema: não há qualquer funcionalidade de natureza financeira, o julgamento esportivo é externo à plataforma, e a interface não detém autoridade para conceder privilégio. Por fim, apresenta os procedimentos de administração de contas, implantação, verificação de saúde, cópia de segurança e diagnóstico de problemas, além do registro explícito das limitações conhecidas.

Palavras-chave: fisiculturismo; gestão esportiva; ranking; segurança da informação; controle de acesso.

LISTA DE SIGLAS E ABREVIATURAS



ABNT	Associação Brasileira de Normas Técnicas
API	<i>Application Programming Interface</i> — interface de programação de aplicações
CORS	<i>Cross-Origin Resource Sharing</i> — compartilhamento de recursos entre origens
CPF	Cadastro de Pessoas Físicas
HTTP	<i>Hypertext Transfer Protocol</i>
JWT	<i>JSON Web Token</i>
LGPD	Lei Geral de Proteção de Dados Pessoais
MCI	Muscle Contest International
ORM	<i>Object-Relational Mapping</i> — mapeamento objeto-relacional
REST	<i>Representational State Transfer</i>
RLS	<i>Row Level Security</i> — segurança em nível de linha
S3	<i>Simple Storage Service</i> — protocolo de armazenamento de objetos
SPA	<i>Single Page Application</i> — aplicação de página única
URL	<i>Uniform Resource Locator</i>

SUMÁRIO

1	INTRODUÇÃO	8
1.1	Objetivo	8
1.2	Público-alvo	8
1.3	Como ler este manual	8
2	APRESENTAÇÃO DO SISTEMA	10
2.1	Definição	10
2.2	Delimitação do escopo	10
2.3	Princípios de projeto	11
3	ARQUITETURA	12
3.1	Visão geral	12
3.2	Componentes	12
3.3	Tecnologias	13
3.4	Modelo de dados	13
4	PAPÉIS E CONTROLE DE ACESSO	15
4.1	Modelo de autorização	15
4.2	Papéis disponíveis	15
4.3	Cadastro aberto e papéis privilegiados	15
4.4	Separação entre organizações	16
5	MÓDULOS FUNCIONAIS	17
5.1	Organizações e filiações	17
5.2	Atletas	17
5.3	Eventos, categorias e classes	17
5.4	Inscrições	18
5.5	Operação do dia do evento	18
5.6	Recepção e publicação de resultados	18
5.7	Ranking	19
5.8	Importação MuscleWar	19
5.9	MCI Social, Messenger e comunidades	19
5.10	Documentos e mídia	19

5.11	Busca e notificações	19
6	REGULAMENTO ESPORTIVO APLICADO	20
6.1	Classes e elegibilidade	20
6.2	Tabela de pontuação	20
6.3	Título Overall	20
6.4	Super Overall anual	21
6.5	Critério de desempate	21
6.6	Equipes e empresas	22
7	FLUXOS OPERACIONAIS	23
7.1	Ciclo completo de uma etapa	23
7.2	Procedimento de dia de evento	23
7.3	Procedimento de resultado	23
7.4	Tratamento de divergência de pontuação	24
8	SEGURANÇA E PROTEÇÃO DE DADOS	25
8.1	Autenticação	25
8.2	Autorização	25
8.3	Isolamento no banco — Row Level Security	25
8.4	Dado pessoal sensível	25
8.5	Auditoria	25
8.6	Proteções de superfície	26
9	ADMINISTRAÇÃO DA PLATAFORMA	27
9.1	Primeiro administrador	27
9.2	Concessão de papéis	27
9.3	Situação das contas	27
10	IMPLANTAÇÃO E OPERAÇÃO	28
10.1	Requisitos	28
10.2	Variáveis de ambiente	28
10.3	Migrações	29
10.4	Sondas de saúde	29
10.5	Cópia de segurança	29
11	DIAGNÓSTICO DE PROBLEMAS	30

11.1	Roteiro rápido	30
11.2	Diagnóstico do armazenamento	30
11.3	O que observar nas primeiras horas	30
12	LIMITAÇÕES E PENDÊNCIAS CONHECIDAS	32
13	GLOSSÁRIO	33
	REFERÊNCIAS	34
	APÊNDICE A – ÍNDICE DE ROTAS POR MÓDULO	35

1 INTRODUÇÃO

Este manual descreve o **MCI Platform**, sistema oficial de operação do Campeonato Brasileiro Muscle Contest International. Reúne, em documento único, a finalidade do sistema, sua arquitetura, os papéis de acesso, os módulos funcionais, o regulamento esportivo tal como implementado, os procedimentos de operação e de implantação, os controles de segurança e as limitações conhecidas.

O conteúdo aqui apresentado foi extraído da própria base de código do sistema — não de intenção de projeto nem de material promocional. Cada regra descrita corresponde a um trecho executável e, na maioria dos casos, a um teste automatizado que a sustenta.

1.1 Objetivo

Fornecer a operadores, administradores e responsáveis técnicos uma referência completa e verificável sobre o que o sistema faz, o que ele deliberadamente não faz, e como conduzi-lo com segurança durante um campeonato.

1.2 Público-alvo

O manual atende quatro perfis, e cada um encontra seu ponto de entrada próprio, conforme o Quadro 1.

Quadro 1 – Público-alvo e seções de interesse

Perfil	Responsabilidade	Seções principais
Administrador da plataforma	Contas, papéis, organizações	4, 8, 9
Operador de evento	Inscrição, check-in, pesagem, credenciais, baterias	5, 6, 7
Responsável técnico	Implantação, sondas, backup, diagnóstico	3, 10, 11
Comitê esportivo	Regulamento aplicado, pontuação, desempate	6, 12

Fonte: elaborado pelo autor (2026).

1.3 Como ler este manual

As seções 2 e 6 são de leitura obrigatória para qualquer perfil: a primeira delimita o escopo do sistema, e a segunda registra o regulamento esportivo efetivamente implementado. As demais podem ser consultadas por necessidade.

Ao longo do texto, os blocos destacados em azul trazem observações operacionais; os destacados em vermelho trazem **advertências** — situações em que uma ação equivocada tem consequência difícil de reverter.

2 APRESENTAÇÃO DO SISTEMA



2.1 Definição

O MCI Platform é uma aplicação web de gestão esportiva construída para o ciclo completo de um campeonato nacional de fisiculturismo: cadastro de atletas e entidades, filiação, inscrição em eventos, operação do dia da competição, recepção e publicação de resultados oficiais, apuração de rankings e uma camada de relacionamento entre os participantes.

A plataforma é **multiorganizacional**: uma mesma instalação atende várias federações e entidades promotoras, com separação de dados garantida no banco, e não apenas na aplicação.

2.2 Delimitação do escopo

Tão importante quanto o que o sistema faz é o que ele deliberadamente não faz. Três exclusões são estruturais e não devem ser interpretadas como funcionalidade ausente ou pendente.

2.2.1 Não é um sistema financeiro

Não há pagamento, cobrança, carteira, saldo, cupom, reembolso, fatura, assinatura ou qualquer forma de movimentação de valores. Essa ausência é verificada por teste automatizado dedicado, que reprova a construção caso termos ou rotas de natureza financeira reapareçam na base de código.

2.2.2 O MCI não julga

O julgamento esportivo é **externo** à plataforma. O sistema recebe a colocação e a pontuação oficiais decididas fora, registra, audita e aplica sobre elas a regra de ranking.

A colocação recebida não é recalculada. Quem chegou em 1º continua em 1º; nenhum critério interno reordena o resultado esportivo. O que chega de fora é dado oficial de entrada, e o papel da plataforma é validar, identificar o atleta, registrar, auditar e ranquear.

Um motor de julgamento interno chegou a existir em fase anterior do projeto e foi **removido** por decisão do organizador. Uma trava em teste recusa o retorno de qualquer rota de julgamento.

2.2.3 O frontend não concede privilégio

Nenhuma decisão de autorização é tomada pela interface. A interface apenas deixa de exibir o que o usuário não pode usar; quem pode o quê é decidido exclusivamente no servidor, a cada requisição. Um formulário adulterado no navegador não amplia acesso.

2.3 Princípios de projeto

Quadro 2 – Princípios que governam o sistema

Princípio	Consequência prática
Negar por padrão	Toda rota exige permissão nomeada; a ausência de regra nega.
Isolamento no banco	<i>Row Level Security</i> do PostgreSQL, não filtro de aplicação.
Rastreabilidade	Todo ato crítico gera registro de auditoria com autor e contexto.
Determinismo esportivo	Mesma entrada, mesma classificação — sempre.
Empate não é resolvido à força	Esgotados os critérios, o empate permanece declarado.
Falhar cedo e em voz alta	Configuração incompleta impede a partida do sistema.

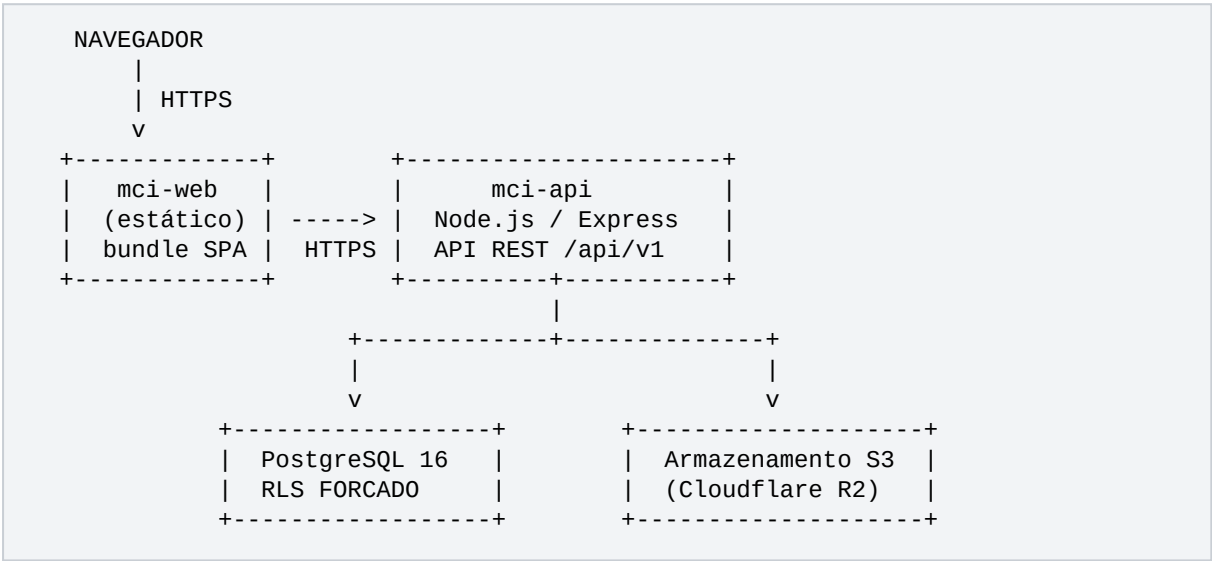
Fonte: elaborado pelo autor (2026) a partir do código-fonte do sistema.

3 ARQUITETURA

3.1 Visão geral

O sistema é composto por três peças independentes e implantadas separadamente, conforme a Figura 1. O servidor de aplicação **não** serve arquivos estáticos: essa é decisão de arquitetura, e não omissão.

Figura 1 – Topologia de implantação



Fonte: elaborado pelo autor (2026).

3.2 Componentes

Quadro 3 – Componentes e responsabilidades

Componente	Responsabilidade
mci-api	Regras de negócio, autorização, persistência, auditoria e integração com o armazenamento.
mci-web	Interface de página única (SPA). Consome exclusivamente a API; não possui banco nem segredo.
mci-db	PostgreSQL 16 com <i>Row Level Security</i> forçado. Fonte única da verdade.
Armazenamento de objetos	Documentos e mídia. Compatível com S3; em produção, Cloudflare R2.

Fonte: elaborado pelo autor (2026).

3.3 Tecnologias

Quadro 4 – Pilha tecnológica

Camada	Tecnologia	Observação
Execução	Node.js 22	Versão de suporte estendido.
Servidor HTTP	Express 5	API REST versionada em /api/v1.
Persistência	Prisma ORM sobre PostgreSQL 16	Migrações versionadas e aditivas.
Validação	Zod	Campos desconhecidos são descartados antes de chegar à regra.
Autenticação	JWT + bcrypt	Senha nunca armazenada em texto claro.
Proteções HTTP	Helmet, CORS restrito, limitador de requisições	Origem curinga é recusada na partida.
Interface	React 19 + Vite	Publicada como sítio estático.
Testes	Node Test Runner e Vitest	30 arquivos de teste no repositório.

Fonte: elaborado pelo autor (2026) a partir de `package.json` e do código-fonte.

3.4 Modelo de dados

O esquema comporta 72 entidades. As centrais estão no Quadro 5; as demais são tabelas de apoio, de vínculo ou de registro histórico.

Quadro 5 – Entidades centrais do domínio

Entidade	Papel no domínio
Organization	Federação ou entidade promotora. Raiz do isolamento de dados.
User	Conta de acesso. Pertence à plataforma, não a uma organização.
Athlete	Ficha esportiva do competidor.
AthleteIdentity	CPF, isolado em tabela própria com proteção de linha.
Event	Etapa do campeonato, com ciclo de vida próprio.
Registration	Inscrição do atleta no evento.
Result / ResultEntry	Resultado oficial recebido e suas colocações.
Ranking	Agregado de pontuação por temporada e recorte.
ClassCatalog	Catálogo de classes e sua elegibilidade ao Super Overall.
Team / Company	Equipe e empresa competidora.
AuditLog	Trilha de auditoria de atos críticos.

Fonte: elaborado pelo autor (2026) a partir de `prisma/schema.prisma`.

OBSERVAÇÃO

As migrações do sistema são **aditivas**: nenhuma delas remove coluna ou tabela. Reverter uma versão é apontar a implantação para o commit anterior — o banco permanece compatível.

4 PAPÉIS E CONTROLE DE ACESSO

4.1 Modelo de autorização

A autorização é **granular por permissão nomeada**, e não por hierarquia de cargos. São 66 permissões e 21 papéis. Rotas e serviços perguntam sempre por uma permissão — nunca por um papel —, e a matriz que liga papéis a permissões é a única fonte de verdade.

Não existe herança por nível: um juiz não é um administrador reduzido, é outro conjunto de permissões. A permissão efetiva de um usuário é a união do papel global com os papéis que ele detém em cada organização.

4.2 Papéis disponíveis

Quadro 6 – Papéis do sistema por natureza

Natureza	Papéis
Administração da plataforma	SUPER_ADMIN, ADMIN
Direção de evento	EVENT_DIRECTOR, EVENT_COORDINATOR
Corpo técnico esportivo	JUDGE_COORDINATOR, JUDGE
Operação de evento	STAFF, REGISTRATION_OPERATOR, CHECKIN_OPERATOR, WEIGHIN_OPERATOR, RESULTS_OPERATOR, RANKING_MANAGER
Comunidade	SOCIAL_ADMIN, MODERATOR
Participantes	ATHLETE, COACH, GYM, TEAM, BRAND, SPONSOR, MEDIA

Fonte: elaborado pelo autor (2026) a partir de `src/utils/roles.js`.

4.3 Cadastro aberto e papéis privilegiados

Os sete papéis de participante — atleta, treinador, academia, equipe, marca, patrocinador e imprensa — são de **cadastro aberto**: qualquer pessoa pode criar a própria conta com um deles. Eles definem **como o usuário aparece** na plataforma, e não o seu nível de acesso.

Os catorze papéis restantes são **privilegiados** e nunca podem ser obtidos por autocadastro. A recusa é aplicada em duas camadas independentes: o esquema de validação da rota de registro aceita apenas os sete papéis abertos, e o serviço de autenticação reverifica a mesma condição antes de gravar.

ADVERTÊNCIA

Nenhum usuário se torna administrador escolhendo uma opção em formulário. Papel privilegiado é **concedido** por quem já administra, com registro de autoria em auditoria. O procedimento consta da seção 9.

4.4 Separação entre organizações

Quem não é de alcance transversal — isto é, quem não é `SUPER_ADMIN` nem `ADMIN` — enxerga apenas as organizações de que participa. A regra vale inclusive para a listagem de usuários: um diretor de federação vê quem divide alguma organização consigo, e mais ninguém.

5 MÓDULOS FUNCIONAIS

A API expõe 140 rotas, distribuídas nos módulos descritos a seguir. O Apêndice A traz o índice completo por prefixo.

5.1 Organizações e filiações

A organização é a raiz do isolamento: evento, atleta, resultado e ranking pertencem sempre a uma. A filiação registra o vínculo formal do atleta ou da entidade com uma federação, entidade, associação ou equipe, e é o que habilita a participação oficial.

5.2 Atletas

A ficha do atleta reúne dados esportivos, situação profissional (NONE, ACTIVE, INACTIVE, SUSPENDED, RETIRED), vínculos e histórico competitivo.

O **CPF não fica na ficha**. Ele reside em tabela separada, protegida por política de linha, e sua consulta é ato auditado. Em nenhuma hipótese o CPF aparece em busca pública ou em listagem aberta.

5.3 Eventos, categorias e classes

O evento percorre um ciclo de vida explícito, apresentado no Quadro 7. Cada transição é registrada em auditoria.

Quadro 7 – Ciclo de vida do evento

#	Situação	Significado
1	DRAFT	Rascunho; invisível ao público.
2	PLANNED	Planejado e divulgado.
3	REGISTRATIONS_OPEN	Inscrições abertas.
4	REGISTRATIONS_CLOSED	Inscrições encerradas.
5	IN_OPERATION	Dia do evento: check-in, pesagem, credenciais.
6	IN_JUDGING	Julgamento em curso — conduzido externamente.
7	RESULTS_IN_REVIEW	Resultado recebido, em conferência, ainda não público.
8	RESULTS_PUBLISHED	Resultado publicado; alimenta o ranking.
9	CLOSED	Evento encerrado.
—	CANCELLED	Evento cancelado.

Fonte: elaborado pelo autor (2026) a partir do enumerado EventStatus.

O catálogo de classes é configurável pela organização, sem alteração de código: criar, editar, ativar, desativar e ordenar classes é operação de administração. A elegibilidade ao Super Overall é **atributo do dado**, e não uma comparação de texto escondida no motor de apuração.

5.4 Inscrições

A inscrição vincula atleta, evento e categoria, e assume uma entre quatro situações: PENDING, CONFIRMED, CANCELLED e REJECTED. Não há etapa de pagamento em nenhum ponto do fluxo — ver a seção 2.2.1.

5.5 Operação do dia do evento

Quatro módulos operam durante a competição, cada um com permissão própria, de modo que o acesso possa ser entregue a equipes distintas.

Quadro 8 – Módulos de operação e respectivas permissões

Módulo	Função	Permissão
Check-in	Confirma a presença do atleta inscrito.	checkin.operate
Pesagem	Registra peso e altura e confronta com a categoria.	weighin.operate
Credenciais	Emite e valida credenciais por tipo de portador.	credentials.manage, credentials.scan
Palco e baterias	Ordena a entrada dos atletas por bateria.	stage.manage

Fonte: elaborado pelo autor (2026) a partir de `src/utils/permissions.js`.

5.6 Recepção e publicação de resultados

O resultado oficial **entra** na plataforma por uma porta de recepção — não é produzido por ela. Recebido, o resultado permanece em rascunho até ser publicado, e essa separação é levada a sério: um visitante ou participante comum não enxerga resultado não publicado, ainda que autenticado. Apenas quem detém `results.read_unpublished` alcança o rascunho, e somente na própria organização.

A publicação é ato distinto da recepção, com permissão própria (`results.publish`) e registro de auditoria. Correções posteriores exigem `results.override` e também são auditadas.

5.7 Ranking

O sistema mantém rankings agregados por temporada, com recortes por atleta, categoria, classe, evento, divisão, equipe e empresa, além do Super Overall anual. As regras estão na seção 6.

5.8 Importação MuscleWar

Importação de resultados em lote a partir do sistema externo. O fluxo é deliberadamente de três tempos: **importar**, **revisar** e **aplicar**, cada um com permissão própria (`musclewar.import`, `musclewar.review`, `musclewar.apply`).

Nada entra no ranking sem passar pela revisão. A identificação do atleta usa CPF e filiação; a operação é idempotente, de modo que reenviar o mesmo lote não duplica pontuação. Cada ponto guarda quem importou, quando e de qual lote veio.

5.9 MCI Social, Messenger e comunidades

Camada de relacionamento entre os participantes: publicações, comentários, reações, *stories*, mensagens diretas e comunidades temáticas. É o maior módulo em número de rotas.

A separação de dados aqui é tão rigorosa quanto no restante: conversa é visível apenas a seus membros, e a política é aplicada no banco.

5.10 Documentos e mídia

Documentos do atleta — identidade, atestado médico, termo, comprovante de filiação — e mídia das publicações são guardados no armazenamento de objetos, nunca no disco do servidor de aplicação. Em ambiente de produção, disco local significa perder todo arquivo enviado no primeiro reinício.

5.11 Busca e notificações

A busca tem duas superfícies: a pública, restrita a dados divulgáveis, e a sensível (`search.sensitive`), acessível a operadores. **CPF nunca aparece em busca pública** — regra verificada por teste.

6 REGULAMENTO ESPORTIVO APLICADO

Esta seção registra as regras **homologadas** pelo organizador do campeonato e implementadas no sistema. Nada aqui é provisório.

6.1 Classes e elegibilidade

Quadro 9 – Classes e elegibilidade ao Super Overall

Classe	Pontua no campeonato	Alimenta o Super Overall
ESTREANTE	Sim	Não
NOVICE	Sim	Não
OPEN	Sim	Sim
MASTER	Sim	Não

Fonte: regulamento homologado do campeonato, conforme docs/phase-11.4-regulamento-ranking.md.

A classe JUNIOR não integra a configuração oficial vigente.

6.2 Tabela de pontuação

Tabela 1 – Pontos por colocação

Colocação	Pontos
1º	5
2º	4
3º	3
4º	2
5º	1
6º em diante	0

Fonte: regulamento homologado do campeonato (2026).

O zero do 6º lugar em diante é **valor definido**, e não lacuna à espera de tabela estendida. A tabela vive no banco, por temporada, e é versionável; não há tabela de pontos escrita na interface.

6.3 Título Overall

O campeão Overall recebe **10 pontos adicionais**, somados aos da colocação. Um primeiro lugar que também seja campeão Overall totaliza, portanto,

15 pontos.

Quem é o campeão Overall é **fato declarado** pelo operador ou pela importação. O sistema não deduz o campeão por algoritmo próprio: a determinação pertence ao regulamento esportivo; ao sistema pertence a pontuação.

6.4 Super Overall anual

Todas as classes pontuam no campeonato; somente a OPEN alimenta o Super Overall anual. O bônus de Overall não possui elegibilidade própria — segue a da participação que o originou.

Quadro 10 – Efeito da elegibilidade sobre as duas métricas

Caso	Campeonato	Super Overall
OPEN, 1º lugar	5	5
OPEN, 1º lugar e Overall	15	15
NOVICE, 1º lugar	5	0
NOVICE, 1º lugar e Overall	15	0
ESTREANTE, 1º lugar e Overall	15	0
MASTER, 1º lugar e Overall	15	0

Fonte: regulamento homologado do campeonato (2026).

As duas métricas são armazenadas em colunas distintas e nunca se misturam. Usar a métrica anual no ranking do campeonato apagaria Estreante, Novice e Master do pódio; usar a do campeonato no anual traria de volta, por dentro, as classes que a regra exclui.

6.5 Critério de desempate

Aplicado na ordem abaixo; o primeiro critério que separar encerra a questão:

1. maior número de títulos Overall;
2. maior número de primeiros lugares;
3. maior número de segundos lugares;
4. maior número de terceiros lugares;
5. empate declarado como TIE_UNRESOLVED.

Quarto e quinto lugares **pontuam** (2 e 1) e **não desempatam**: pontuação e desempate são conceitos distintos, e os contadores de 4º e 5º existem apenas para auditoria.

REGRA INEGOCIÁVEL

Esgotada a hierarquia, o empate **não é quebrado**. Não se usa identificador, nome, CPF, data, ordem de inscrição, ordem alfabética nem sorteio. Os empatados permanecem sem colocação, marcados como empate não resolvido, e a decisão retorna a quem tem competência para tomá-la.

6.6 Equipes e empresas

Aplicam-se a mesma tabela, o mesmo bônus, o mesmo desempate e a mesma elegibilidade — sem fórmula, peso, multiplicador ou critério próprio. A hierarquia é: empresa, equipe, atleta.

Um atleta possui **vínculo ativo único** com equipe ou empresa. A tentativa de criar um segundo vínculo ativo é recusada, inclusive sob requisições simultâneas — condição verificada por teste de concorrência.

7 FLUXOS OPERACIONAIS

7.1 Ciclo completo de uma etapa

A Figura 2 apresenta a sequência de ponta a ponta, do cadastro do evento à atualização do ranking.

Figura 2 – Fluxo de ponta a ponta de uma etapa

1. CRIAR EVENTO	direção do evento define etapa, categorias e classes
2. ABRIR INSCRICOES	atletas e treinadores inscrevem
3. FECHAR INSCRICOES	lista de participantes consolidada
4. DIA DO EVENTO	check-in -> pesagem -> credencial -> baterias
5. JULGAMENTO	EXTERNO ao sistema
6. RECEBER RESULTADO	colocacao e pontuacao oficiais entram na plataforma
7. CONFERIR	rascunho visivel apenas a quem tem a permissao
8. PUBLICAR	ato proprio, auditado
9. RANKING	pontos agregados por temporada e recorte

Fonte: elaborado pelo autor (2026).

7.2 Procedimento de dia de evento

No dia da competição, a ordem das operações é a seguinte:

1. colocar o evento na situação `IN_OPERATION`;
2. realizar o **check-in** dos atletas inscritos e confirmados;
3. realizar a **pesagem**, conferindo o enquadramento na categoria;
4. emitir as **credenciais** por tipo de portador;
5. organizar as **baterias** e a ordem de entrada em palco;
6. transferir o evento para `IN_JUDGING`.

7.3 Procedimento de resultado

1. receber o resultado oficial, por lançamento direto ou por importação;
2. conferir o rascunho, inclusive a origem de cada pontuação;
3. tratar eventuais divergências marcadas como conflito (seção 7.4);
4. publicar, o que torna o resultado visível e alimenta o ranking;

5. encerrar o evento.

7.4 Tratamento de divergência de pontuação

Quando a pontuação recebida diverge daquela que a regra da temporada calcula, o sistema **não escolhe em silêncio**: registra um conflito auditável, com os dois números e a diferença à vista, para decisão humana.

OBSERVAÇÃO

Um sexto lugar valendo zero **não** é conflito — é a regra. Conflito é divergência entre o valor recebido e o valor que a regra produz para a mesma colocação.

8 SEGURANÇA E PROTEÇÃO DE DADOS



8.1 Autenticação

O acesso usa credencial de e-mail e senha, com *hash* bcrypt e fator de custo mínimo de 10 em produção. A sessão é um *token* JWT assinado, cujo segredo precisa ter ao menos 32 caracteres e não pode ser valor de exemplo — as duas condições são verificadas na partida da aplicação. Trocar o segredo encerra todas as sessões, o que é efeito esperado.

8.2 Autorização

Toda rota protegida declara a permissão exigida. A verificação acontece no servidor, em duas camadas: no roteador, antes de chegar à regra de negócio, e dentro do serviço, novamente. A dupla verificação existe para que uma rota registrada sem proteção não abra caminho silencioso.

8.3 Isolamento no banco — *Row Level Security*

Vinte e uma tabelas operam com `FORCE ROW LEVEL SECURITY` do PostgreSQL. A palavra `FORCE` é essencial: sem ela, o dono da tabela ignora as próprias políticas.

Cada requisição executa em um contexto de ator propagado até a conexão do banco, de modo que a política de linha sabe quem está perguntando. A aplicação **recusa subir** em duas hipóteses: se a conexão for de superusuário, ou se qualquer tabela protegida estiver sem `FORCE`. Não há modo degradado — o sistema falha na partida e diz qual é o problema.

8.4 Dado pessoal sensível

O CPF é tratado como dado de acesso restrito: reside em tabela separada, com política própria, e sua consulta gera registro de auditoria específico. Não aparece em busca pública, em listagem aberta nem em resposta de rota pública.

8.5 Auditoria

Atos críticos geram registro em trilha própria, com autor, e-mail do autor, entidade afetada, identificador, organização, dados de contexto e endereço de origem. A trilha inclui, entre outros, autenticação, criação e alteração de atleta, consulta de CPF, inscrição e cancelamento, check-in, pesagem, emissão e leitura de credencial, transições de evento, recepção, publicação e correção de resultado,

atualização de ranking, importação MuscleWar, vínculo e transferência de equipe, mudança de papel e bootstrap administrativo.

A própria trilha é protegida por política de linha: sua leitura exige permissão de administração ou de operação na organização.

OBSERVAÇÃO

A gravação da auditoria é efeito colateral deliberadamente tolerante a falha: uma falha ao auditar não derruba a operação auditada, mas é registrada no log da aplicação. Procedimentos críticos, como a concessão de papel privilegiado, devem ser **conferidos na trilha** após a execução, e não presumidos.

8.6 Proteções de superfície

Quadro 11 – Controles de superfície HTTP

Controle	Comportamento
Cabeçalhos de segurança	Aplicados por Helmet em todas as respostas.
CORS	Lista explícita de origens. Curinga é recusado na partida.
Limite de requisições	Ativo em produção, sensível ao número de saltos de proxy configurado.
Validação de entrada	Campos desconhecidos são descartados antes de alcançar a regra de negócio.
Erros internos	Resposta 5xx nunca expõe código de banco ou detalhe interno; o diagnóstico real vai para o log.

Fonte: elaborado pelo autor (2026) a partir do código-fonte do sistema.

9 ADMINISTRAÇÃO DA PLATAFORMA

9.1 Primeiro administrador

Como o cadastro aberto recusa papel privilegiado — e deve recusar —, uma instalação nova não teria como dar o primeiro passo. Para isso existe uma ferramenta de linha de comando, executada no ambiente da própria aplicação:

```
read -rsp 'Senha do administrador: ' ADMIN_PASSWORD; echo
export ADMIN_PASSWORD
node scripts/criar-admin.js "Nome Completo" email@dominio
unset ADMIN_PASSWORD
```

A senha não é aceita como argumento de linha de comando: argumento aparece na listagem de processos e fica no histórico do interpretador de comandos. A ferramenta registra o ato na auditoria como ADMIN_BOOTSTRAP.

Se o endereço informado já pertencer a um usuário, a conta existente é **promovida no lugar**, preservando identificador, perfil e histórico. Nesse caso, a senha da conta também é redefinida para a informada no comando.

ADVERTÊNCIA

A ferramenta cria **apenas o primeiro** administrador: havendo qualquer SUPER_ADMIN na instalação, ela se recusa a executar e nada é gravado. Há, portanto, uma única tentativa — confira o endereço de e-mail antes de executar. Endereço divergente resulta em conta nova, e não em promoção.

9.2 Concessão de papéis

Estabelecido o primeiro administrador, toda concessão posterior passa pela administração de contas, sujeita a três regras cumulativas:

- a) é exigida a permissão `users.manage`, detida por SUPER_ADMIN e ADMIN;
- b) ninguém altera o próprio papel ou a própria situação;
- c) somente SUPER_ADMIN concede papel privilegiado — um ADMIN administra contas, mas não fabrica pares.

A operação gera registro `ROLE_CHANGE`, com o papel anterior e o novo lado a lado, e o autor da concessão identificado.

9.3 Situação das contas

Uma conta assume uma entre três situações: ACTIVE, SUSPENDED e DISABLED. A alteração é auditada, e também aqui vale a proibição de alterar a própria situação.

10 IMPLANTAÇÃO E OPERAÇÃO

10.1 Requisitos

- a) PostgreSQL 16, acessado por papel **não superusuário**;
- b) armazenamento de objetos compatível com S3, com credencial restrita a um único *bucket*;
- c) ambiente de execução Node.js 22, ou a imagem de contêiner do repositório;
- d) host estático para o pacote da interface.

10.2 Variáveis de ambiente

Quadro 12 – Variáveis exigidas em produção

Variável	Valor e observação
NODE_ENV	production.
DATABASE_URL	Conexão do banco. Papel sem privilégio de superusuário.
JWT_SECRET	No mínimo 32 caracteres; valor de exemplo é recusado.
BCRYPT_ROUNDS	Mínimo 10 em produção.
CORS_ORIGINS	Origens completas, com esquema, sem barra final. Curinga é recusado.
RATE_LIMIT_ENABLED	true em produção.
TRUST_PROXY_HOPS	Número de proxies à frente da aplicação.
STORAGE_DRIVER	s3.
S3_ENDPOINT	Somente o host da conta, sem o <i>bucket</i> no caminho.
S3_BUCKET	Nome do <i>bucket</i> .
S3_ACCESS_KEY_ID	Chave de acesso do token de armazenamento.
S3_SECRET_ACCESS_KEY	Segredo correspondente. Nunca versionado.
S3_REGION	auto no Cloudflare R2.
S3_FORCE_PATH_STYLE	true no Cloudflare R2.
DEFAULT_TIMEZONE	America/Sao_Paulo.

Fonte: elaborado pelo autor (2026) a partir de `src/config/environment.js`.

ADVERTÊNCIA

Segredos não são versionados, não são impressos em log e não são transmitidos por conversa. A chave de serviço do banco jamais deve alcançar a interface.

10.3 Migrações

Em produção, e somente:

```
npx prisma migrate deploy
```

Nunca migrate dev e nunca db push: ambos podem reescrever o esquema sem registro.

10.4 Sondas de saúde

Quadro 13 – Sondas expostas pela aplicação

Rota	Finalidade	Resposta esperada
/health	Processo vivo	200
/ready	Apto a receber tráfego	Banco, armazenamento e RLS verdadeiros

Fonte: elaborado pelo autor (2026).

A sonda /ready é pública e, por isso, explica a própria reprovação sem expor conteúdo sensível: informa o código de situação e o código do serviço de armazenamento, nunca o corpo bruto da resposta de erro — o XML de erro de credencial em S3 carrega a chave de acesso por inteiro.

10.5 Cópia de segurança

O repositório traz rotina própria de cópia e restauração, com ensaios cobertos pela suíte de testes. Ela exige um papel de banco com BYPASSRLS e um destino de armazenamento, e deve ser configurada **antes** do primeiro evento real.

11 DIAGNÓSTICO DE PROBLEMAS

11.1 Roteiro rápido

Quadro 14 – Sintomas, causas prováveis e conduta

Sintoma	Causa provável	Conduta
A aplicação não sobe e acusa RLS	Conexão de superusuário, ou tabela sem FORCE	Usar papel comum; reaplicar as migrações
/ready com armazenamento falso	Credencial, permissão ou <i>bucket</i> incorretos	Executar o diagnóstico de armazenamento (11.2)
Interface acusa bloqueio de origem	CORS_ORIGINS divergente da URL real	Corrigir a origem, com esquema e sem barra final
Interface não encontra a API	VITE_API_URL lida em tempo de construção	Reconstruir a interface após alterar a variável
Recarregar uma rota devolve 404	Ausência de reescrita para <code>index.html</code>	Configurar a reescrita no host estático
Primeira requisição muito lenta	Hibernação de plano gratuito	Migrar para plano pago antes da competição
Empate sem colocação no ranking	Comportamento correto: empate não resolvido	Decisão do comitê; o sistema não desempata por conta própria

Fonte: elaborado pelo autor (2026).

11.2 Diagnóstico do armazenamento

Executado no ambiente da aplicação, onde as variáveis já existem:

```
node scripts/diagnostico-r2.js
```

A ferramenta exercita o ciclo completo — verificação, gravação, confirmação, metadados, leitura, remoção e nova confirmação — e indica onde parou. Nenhum segredo é impresso: a chave de acesso aparece apenas pelos quatro últimos caracteres, e o segredo, nunca. Acusa também espaço ou quebra de linha sobrando nas variáveis, que é o defeito de configuração mais comum e o mais difícil de enxergar em painel de administração.

11.3 O que observar nas primeiras horas

- taxa de respostas 5xx, cuja linha de base medida é zero nas rotas principais;
- latência da consulta de ranking, que é a tela mais visitada;

- c) respostas 401 e 403 concentradas em uma origem;
- d) comparação entre a consulta de ranking anônima e autenticada, que devem coincidir.

12 LIMITAÇÕES E PENDÊNCIAS CONHECIDAS

Esta seção existe para que nenhuma limitação seja descoberta durante um evento.

Quadro 15 – Pendências registradas

Item	Situação
Homologação esportiva do critério de campeão Overall	Pendente de decisão do comitê. Independe do sistema.
Domínio próprio	Enquanto o endereço for de subdomínio do provedor, trata-se de endereço de teste.
Rotina de cópia de segurança em produção	Implementada e ensaiada; exige configuração de papel e destino.
Arquivo de infraestrutura declarativa	Escrito, porém não validado contra o provedor; o roteiro manual é o caminho verificado.
Tabelas remanescentes do antigo motor de julgamento	Permanecem no banco por vedação a migração destrutiva; nenhum código as alcança.

Fonte: elaborado pelo autor (2026).

13 GLOSSÁRIO



Bateria	Agrupamento de atletas para entrada em palco, em ordem definida pela organização.
Classe	Recorte competitivo — Estreante, Novice, Open, Master — com elegibilidade própria ao Super Overall.
Conflito de pontuação	Divergência entre a pontuação recebida e a calculada pela regra da temporada, registrada para decisão humana.
Elegibilidade	Atributo da classe que determina se sua pontuação alimenta o Super Overall anual.
Multiorganizacional	Capacidade de uma mesma instalação atender várias organizações com dados isolados.
Overall	Título de campeão absoluto do evento, declarado externamente, que acrescenta 10 pontos.
Papel privilegiado	Papel que não pode ser obtido por autocadastro e depende de concessão auditada.
Permissão	Unidade nomeada de autorização verificada pelo servidor a cada requisição.
RLS	<i>Row Level Security</i> : isolamento aplicado pelo próprio banco de dados, linha a linha.
Super Overall	Ranking anual alimentado exclusivamente pelas classes elegíveis.
Temporada	Ciclo anual que agrega eventos, pontuações e rankings.
Trilha de auditoria	Registro imutável de atos críticos, com autor, contexto e momento.

REFERÊNCIAS



ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6023**: informação e documentação: referências: elaboração. Rio de Janeiro: ABNT, 2018.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6024**: informação e documentação: numeração progressiva das seções de um documento: apresentação. Rio de Janeiro: ABNT, 2012.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6027**: informação e documentação: sumário: apresentação. Rio de Janeiro: ABNT, 2012.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6028**: informação e documentação: resumo, resenha e resenha: apresentação. Rio de Janeiro: ABNT, 2021.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 10520**: informação e documentação: citações em documentos: apresentação. Rio de Janeiro: ABNT, 2023.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 14724**: informação e documentação: trabalhos acadêmicos: apresentação. Rio de Janeiro: ABNT, 2011.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União: seção 1, Brasília, DF, ano 155, n. 157, p. 59, 15 ago. 2018.

JONES, M.; BRADLEY, J.; SAKIMURA, N. **RFC 7519**: JSON Web Token (JWT). [S. l.]: Internet Engineering Task Force, 2015. Disponível em: <https://www.rfc-editor.org/rfc/rfc7519>. Acesso em: 12 set. 2026.

OWASP FOUNDATION. **OWASP Top 10: 2021**. [S. l.]: OWASP, 2021. Disponível em: <https://owasp.org/Top10/>. Acesso em: 12 set. 2026.

POSTGRESQL GLOBAL DEVELOPMENT GROUP. **PostgreSQL 16 documentation**: row security policies. [S. l.]: PostgreSQL, 2023. Disponível em: <https://www.postgresql.org/docs/16/ddl-rowsecurity.html>. Acesso em: 12 set. 2026.

MUSCLE CONTEST INTERNATIONAL. **Regulamento do ranking**: regras oficiais do Campeonato Brasileiro Muscle Contest International. [S. l.]: MCI, 2026. Documento interno do projeto.

MUSCLE CONTEST INTERNATIONAL. **MCI Platform**: código-fonte do sistema. [S. l.]: MCI, 2026. Repositório de desenvolvimento.

APÊNDICE A – ÍNDICE DE ROTAS POR MÓDULO

Distribuição das 140 rotas da API, agrupadas pelo prefixo de primeiro nível, sob a base /api/v1.

Quadro 16 – Rotas por prefixo

Prefixo	Rotas	Módulo
/social	27	Publicações, comentários, reações, <i>stories</i>
/events	13	Eventos e ciclo de vida
/athletes	11	Atletas e vínculos
/messenger	10	Conversas e mensagens
/communities	6	Comunidades
/registrations	5	Inscrições
/ranking	5	Rankings e Super Overall
/public	5	Superfície pública
/musclewar	5	Importação externa
/classes	5	Classes e recepção de resultado
/organizations	4	Organizações e membros
/seasons, /profile, /notifications, /documents, /dashboard, /auth, /affiliations, /admin	3 cada	Temporadas, perfil, notificações, documentos, painéis, autenticação, filiações, administração
/partnerships, /media, /batches	2 cada	Parcerias, mídia, baterias
Demais prefixos	1 cada	Equipes, patrocínios, patrocinadores, busca, academias, categorias de evento, divisões, credenciais, empresas, treinadores, catálogo de classes, categorias, marcas, auditoria

Fonte: elaborado pelo autor (2026) a partir de `src/routes/index.js`.